**AEGIS BANK**

**GDPR & Privacy Policy**

***Enterprise AI Decision & Knowledge Platform for Modern Banking***

---

**Document Information**

| Field | Details |
|---|---|
| **Document Title** | GDPR & Privacy Policy |
| **Document ID** | **AB-COMP-001** |
| **Department** | Compliance & Data Protection |
| **Version** | v1.2 |
| **Last Updated** | July 24, 2026 |
| **Document Owner** | Data Protection Officer (DPO) |
| **Classification** | Confidential |
| **Review Date** | July 24, 2027 |
| **Approved By** | **Sami Khan – Chief Executive Officer (CEO)** |

---

**Confidentiality Notice**

This GDPR & Privacy Policy defines how Aegis Bank collects, processes, stores, protects, and manages personal information in accordance with the General Data Protection Regulation (GDPR) and applicable data protection requirements.

This document applies to all employees, contractors, third-party providers, and systems handling personal data.

Unauthorized disclosure or misuse of personal information is strictly prohibited.

---

**Table of Contents**

1. Purpose

2. Scope
3. GDPR Principles
4. Personal Data Definition
5. Data Processing Rules
6. Lawful Basis for Processing
7. Customer Data Rights
8. Data Collection Requirements
9. Data Storage & Protection
10. Data Sharing Requirements
11. Data Retention
12. Data Breach Management
13. AI & GDPR Requirements
14. Employee Responsibilities
15. Practical Examples
16. FAQs
17. Revision History
18. Document Approval

---

**1. Purpose**

The purpose of this policy is to establish a privacy framework that ensures Aegis Bank processes personal information securely, transparently, and responsibly.

The policy aims to:

- Protect customer privacy.
- Ensure GDPR compliance.
- Establish responsible data handling practices.
- Reduce privacy risks.

- Maintain customer trust.
- Support secure AI-driven banking operations.

---

**2. Scope**

This policy applies to:

- Customers.
- Employees.
- Contractors.
- Business partners.
- Third-party service providers.

It covers personal data processed through:

- Banking applications.
- Customer portals.
- Mobile applications.
- Loan systems.
- KYC platforms.
- CRM systems.
- AI platforms.
- Internal business systems.

---

**3. GDPR Principles**

Aegis Bank follows the seven core GDPR principles.

---

**1. Lawfulness, Fairness & Transparency**

Personal data must be processed legally and customers must understand how their information is used.

---

**2. Purpose Limitation**

Data must only be collected and used for defined business purposes.

Example:

Customer identity information collected for KYC verification must not be used for unrelated purposes.

---

**3. Data Minimization**

Aegis Bank collects only the information necessary for legitimate banking activities.

---

**4. Accuracy**

Customer information must remain accurate and updated.

---

**5. Storage Limitation**

Personal data must not be retained longer than required.

---

**6. Integrity & Confidentiality**

Personal information must be protected through appropriate security controls.

---

**7. Accountability**

Aegis Bank must demonstrate compliance through:

- Policies.
- Audits.
- Documentation.
- Security controls.

---

**4. Personal Data Definition**

Personal data includes any information that can identify an individual.

Examples:

- Full name.
- Address.
- Email address.
- Phone number.
- Date of birth.
- Identification documents.
- Account information.
- Transaction history.
- Financial records.

---

**Sensitive Personal Data**

Examples:

- Biometric information.
- Identity verification data.
- Financial information.
- Authentication information.

Sensitive data requires enhanced protection.

---

**5. Data Processing Rules**

Aegis Bank processes personal data only when:

- There is a legitimate business purpose.
- Processing is legally permitted.
- Appropriate security controls exist.

- Access is authorized.

All processing activities must be documented.

---

**6. Lawful Basis for Processing**

Aegis Bank processes customer information under approved legal bases.

---

**Contractual Requirement**

Example:

Processing customer information to provide banking services.

---

**Legal Obligation**

Example:

Maintaining records required by financial regulations.

---

**Legitimate Interest**

Example:

Fraud detection and cybersecurity monitoring.

---

**Customer Consent**

Example:

Optional marketing communications.

---

**7. Customer Data Rights**

Under GDPR, customers have the following rights:

---

**Right of Access**

Customers may request information about their stored personal data.

---

**Right to Correction**

Customers may request inaccurate information to be updated.

---

**Right to Deletion**

Customers may request deletion of personal information where legally applicable.

---

**Right to Restrict Processing**

Customers may request limitations on how their data is processed.

---

**Right to Data Portability**

Customers may request their information in a structured format.

---

**Right to Object**

Customers may object to certain processing activities.

---

**8. Data Collection Requirements**

Aegis Bank must:

- Inform customers before collecting data.
- Collect only necessary information.
- Maintain privacy notices.
- Record processing activities.
- Protect collected information.

Customer data collection examples:

- Account opening.

- KYC verification.
- Loan applications.
- Fraud prevention.
- Customer support.

---

**9. Data Storage & Protection**

Personal data must be protected through:

- Encryption.
- Access controls.
- MFA.
- Monitoring.
- Secure backups.
- Audit logging.

Confidential and Restricted customer data must only be stored in approved systems.

---

**10. Data Sharing Requirements**

Personal information may only be shared with:

- Authorized employees.
- Approved service providers.
- Regulatory authorities.
- Legal entities when required.

Before sharing data:

- Purpose must be verified.
- Security requirements must be reviewed.
- Appropriate agreements must exist.

---

**11. Data Retention**

Aegis Bank retains personal information only for as long as necessary.

Retention decisions consider:

- Regulatory requirements.
- Business needs.
- Legal obligations.
- Security requirements.

Expired data must be securely deleted or anonymized.

---

**12. Data Breach Management**

Any privacy incident must be handled according to:

**AB-SEC-004 — Cyber Security Incident Response Plan**

Examples:

- Unauthorized customer data access.
- Lost customer documents.
- Accidental information disclosure.

Response steps:

1. Detect incident.
2. Contain impact.
3. Investigate cause.
4. Assess affected data.
5. Notify required parties.
6. Implement improvements.

---

**13. AI & GDPR Requirements**

Aegis Bank's AI systems, including **Aegis AI OS**, must follow privacy requirements.

AI systems must:

- Process data only for approved purposes.
- Protect customer information.
- Maintain access controls.
- Provide audit trails.
- Prevent unauthorized data exposure.

AI models must not use customer personal information without proper authorization and governance approval.

---

**14. Employee Responsibilities**

Employees must:

- Protect customer information.
- Follow privacy procedures.
- Access data only when required.
- Report privacy incidents.
- Complete privacy training.

Employees must not:

- Share customer data without approval.
- Store personal data on unauthorized devices.
- Export customer information without authorization.

---

**15. Practical Examples**

**Example 1 — Customer Loan Application**

A customer submits:

- Identity documents.
- Income details.

- Financial information.

Classification:

➡️ Confidential Personal Data

Protection:

- Encryption.
- Authorized access.
- Secure storage.

---

**Example 2 — Customer Requests Data Deletion**

A customer requests removal of personal information.

Process:

- Verify customer identity.
- Review legal obligations.
- Delete eligible information.
- Record completion.

---

**Example 3 — AI Customer Assistant**

Customer asks AI chatbot about account services.

Requirements:

- Customer identity verification.
- Secure data access.
- Privacy monitoring.

---

**16. Data Protection Officer (DPO) Responsibilities**

The Data Protection Officer (DPO) is responsible for overseeing privacy governance and ensuring that Aegis Bank maintains compliance with GDPR requirements.

The DPO responsibilities include:

- Monitoring privacy compliance.
- Advising departments on data protection requirements.
- Reviewing privacy risks.
- Supporting Privacy Impact Assessments.
- Managing customer privacy requests.
- Coordinating with regulatory authorities.
- Conducting privacy awareness programs.
- Supporting internal audits.

---

**17. Privacy Impact Assessment (PIA)**

Aegis Bank performs Privacy Impact Assessments before implementing systems or processes that may create significant privacy risks.

PIA is required for:

- New AI systems.
- Customer data processing projects.
- Large-scale data analytics.
- Biometric processing.
- New third-party integrations.
- High-risk technology implementations.

---

**PIA Process**

**Step 1 — Identify Data Processing**

Determine:

- What data is collected.

- Why it is collected.
- Who can access it.
- Where it is stored.

---

**Step 2 — Assess Privacy Risks**

Evaluate:

- Unauthorized access risks.
- Data exposure risks.
- Compliance risks.
- Customer impact.

---

**Step 3 — Implement Controls**

Controls may include:

- Encryption.
- Access restrictions.
- Data anonymization.
- Monitoring.
- Additional approvals.

---

**Step 4 — Review & Approval**

The Data Protection Officer reviews the assessment before implementation.

---

**18. Third-Party Privacy Management**

Aegis Bank requires third-party providers handling personal information to follow privacy and security standards.

Before onboarding a third party:

- Privacy assessment must be completed.
- Data processing agreements must be signed.
- Security controls must be reviewed.
- Access requirements must be defined.

---

**Third-Party Requirements**

Service providers must:

- Protect customer information.
- Process data only for approved purposes.
- Maintain confidentiality.
- Report privacy incidents.
- Delete data after contractual requirements end.

Examples:

- Cloud providers.
- Payment processors.
- Customer support platforms.
- Identity verification providers.

---

**19. International Data Transfers**

When personal information is transferred across countries, Aegis Bank must ensure appropriate protection measures are applied.

Requirements include:

- Approved transfer mechanisms.
- Data protection agreements.
- Vendor security reviews.
- Regulatory compliance checks.

Cross-border transfers must not reduce the level of customer privacy protection.

---

**20. Privacy by Design & Default**

Aegis Bank follows Privacy by Design principles.

Privacy considerations must be included during:

- System development.
- Application design.
- AI implementation.
- Database architecture.
- Process creation.

---

**Privacy by Default Requirements**

Systems should:

- Collect minimum required data.
- Restrict unnecessary access.
- Enable security controls automatically.
- Protect customer information by default.

---

**21. Employee Privacy Rules**

Employees handling personal information must follow strict privacy requirements.

Employees must:

- Verify authorization before accessing data.
- Use approved systems only.
- Protect customer documents.
- Lock devices when unattended.
- Report privacy concerns immediately.

Employees must not:

- Download customer data unnecessarily.
- Share customer records through personal email.
- Discuss customer information publicly.
- Access accounts without business justification.

---

**22. Privacy Violation Handling**

Privacy violations must be reported immediately.

Examples:

- Sending customer data to the wrong person.
- Unauthorized database access.
- Lost documents containing personal information.
- Improper use of customer information.

---

**Response Process**

When a privacy violation occurs:

**Step 1 — Report**

Employee informs:

- Data Protection Officer.
- Information Security Team.
- Department Manager.

---

**Step 2 — Investigation**

The Bank evaluates:

- Type of data involved.
- Number of affected individuals.

- Risk level.
- Regulatory impact.

---

**Step 3 — Corrective Actions**

Actions may include:

- Removing unauthorized access.
- Updating security controls.
- Employee training.
- Policy improvements.

---

**23. GDPR Audit Requirements**

Aegis Bank conducts regular privacy reviews to ensure compliance.

Audit activities include:

- Reviewing data processing activities.
- Checking access permissions.
- Verifying security controls.
- Reviewing vendor compliance.
- Testing privacy procedures.

Audit findings must be documented and tracked until resolution.

---

**24. Practical GDPR Banking Scenarios**

---

**Scenario 1 — Customer Data Access Request**

A customer requests a copy of all personal information held by Aegis Bank.

**Process:**

1. Verify customer identity.

2. Locate stored personal information.
3. Review legal restrictions.
4. Provide approved data report.

**GDPR Right:**

➡️ Right of Access

---

**Scenario 2 — Incorrect Customer Information**

A customer notices incorrect personal details.

**Process:**

1. Verify customer request.
2. Update incorrect information.
3. Record the change.
4. Confirm completion.

**GDPR Right:**

➡️ Right to Correction

---

**Scenario 3 — AI Document Search System**

An employee uses Aegis AI OS to search internal banking policies.

Requirements:

- User authentication required.
- Access based on employee role.
- Document permissions enforced.
- AI activity logged.

---

**Scenario 4 — External Vendor Access**

A payment service provider requires customer transaction data.

Requirements:

- Vendor assessment.
- Data processing agreement.
- Limited access.
- Security monitoring.

---

**25. Frequently Asked Questions (FAQs)**

**Q1. What is GDPR?**

GDPR is a European data protection regulation that establishes rules for collecting, processing, and protecting personal information.

---

**Q2. Who is responsible for privacy compliance at Aegis Bank?**

The Data Protection Officer oversees privacy compliance with support from departments across the Bank.

---

**Q3. Can Aegis Bank collect any customer information it wants?**

No. The Bank only collects information necessary for legitimate and approved business purposes.

---

**Q4. Can customers request deletion of their data?**

Yes, customers may request deletion where legally permitted.

---

**Q5. How does Aegis Bank protect customer information?**

Through encryption, access controls, MFA, monitoring, security policies, and privacy governance processes.

---

**Q6. Does GDPR apply to AI systems?**

Yes. AI systems processing personal information must follow GDPR requirements, including transparency, security, and controlled access.

---

**26. Related Documents**

This policy should be read together with:

- Customer Privacy Policy (AB-COMP-002)
- Risk Management Framework (AB-COMP-003)
- Internal Audit Manual (AB-COMP-004)
- Regulatory Compliance Manual (AB-COMP-005)
- Data Classification Policy (AB-SEC-005)
- Cyber Security Policy (AB-SEC-003)
- AI Usage Policy (AB-AI-001)

---

**27. Revision History**

| Version | Date | Description | Author |
|---|---|---|---|
| v1.0 | February 10, 2026 | Initial GDPR Privacy Framework Release | Compliance & Data Protection |
| v1.1 | May 15, 2026 | Added AI Privacy Controls and Third-Party Requirements | Data Protection Officer |
| **v1.2** | **July 24, 2026** | **Enhanced GDPR Rights Management, Privacy Auditing, and AI Governance Requirements** | **Compliance & Data Protection Department** |

---

**28. Document Approval**

| Field | Details |
|---|---|
| **Document ID** | **AB-COMP-001** |
| **Document Title** | **GDPR & Privacy Policy** |

| Field | Details |
|---|---|
| **Department** | Compliance & Data Protection |
| **Version** | **v1.2** |
| **Classification** | **Confidential** |
| **Document Owner** | Data Protection Officer (DPO) |
| **Approved By** | **Sami Khan – Chief Executive Officer (CEO)** |
| **Approval Date** | **July 24, 2026** |
| **Next Review Date** | **July 24, 2027** |

---

**Document Control**

| Attribute | Value |
|---|---|
| **Document Status** | Approved |
| **Distribution** | Compliance, Legal, Information Security, IT, Risk Management, All Employees |
| **Language** | English |
| **Storage Location** | Aegis Bank Document Management System (DMS) |
| **Retention Period** | 7 Years |
| **Supersedes** | GDPR & Privacy Policy v1.1 |

---

**End of Document**

**Aegis Bank**
**Enterprise AI Decision & Knowledge Platform for Modern Banking**

**© 2026 Aegis Bank. All Rights Reserved.**